

Nom : WIDAMOU YANDA

NIVEAU : MASTER 2

FILIERE : SISD

EXERCICE III : CHAPITRE 3

Ex. 3.1 Ecriture de la regle suricata

L'objectif est de détecter une commande spécifique (`nc -e /bin/bash`) sortant du VLAN 20 vers des ports inhabituels.

La règle proposée :

```
alert tcp $VLAN20_NET any -> $EXTERNAL_NET ![80,443,22]
(msg:"ATTACK Netcat Reverse Shell Attempt (VLAN 20)"; content:"nc
"; content:"-e "; content:"/bin/bash"; flow:established,to_server;
classtype:attempted-admin; metadata:mitre_technique_id T1059,
mitre_technique_name Command_and_Scripting_Interpreter;
sid:1000001; rev:1;)
```

Détails de cette règle :

- **Action : alert** (génère un log sans bloquer, typique d'un IDS).
- **Source : \$VLAN20_NET** (votre variable réseau pour le VLAN 20).
- **Destination : ![80,443,22]**.
- **Mapping MITRE : Technique T1059** (Command and Scripting Interpreter).
- **SID : 1000001** (ID unique dans la plage réservée aux règles locales).

Ex. 3.3 Plan de déploiement IDS.

Voici une proposition de structure pour sécuriser l'infrastructure :

Composant	Type	Localisation	Mode	Règles Prioritaires
Périmètre	NIDS (Suricata)	Entre le routeur et le Firewall	TAP (Copie flux)	Exploits critiques (RCE), C2 traffic
Serveurs Web	HIDS (Wazuh)	Installé sur chaque VM	Agent	Modifs fichiers /etc (pour linux), Logs Apache
Postes Travail	EDR	Postes administratifs	Inline	Exécution Powershell, Clés USB

EXERCICE VI : CHAPITRE 4

Ex. 4.1 qualification juridique

Dans ce scénario, un employé outrepassé ses droits pour exporter des données massives. Selon la **Loi 2010/012 relative à la cybersécurité et la cybercriminalité au Cameroun** :

- **Infractions potentielles :**
 - **Accès illégitime :** Accès à tout ou partie d'un système informatique sans droit (atteinte à la confidentialité).
 - **Atteinte à l'intégrité des données :** L'extraction non autorisée de 50 000 dossiers peut être qualifiée de vol de données numériques ou détournement de fichiers.
- **Preuves à collecter :**
 - **Logs d'accès au SGBD :** Pour prouver l'heure, l'identifiant utilisé et la requête d'exportation.
 - **Logs réseaux (SIEM) :** Pour tracer le transfert des données vers un support externe ou un Cloud.
 - **Éléments physiques :** Clés USB ou historique de navigation sur le poste de l'employé.
- **Délai de notification à l'ANTIC :** La loi impose généralement une notification **immédiate** ou dans un délai de **72 heures** maximum après la découverte d'un incident grave touchant des données sensibles.

Ex. 4.2 chaîne de custody

Voici un modèle de Procès-Verbal (PV) de saisie respectant les principes ACPO (pas de modification de l'original) et ISO 27037 (identification, collecte, acquisition, préservation) :

PV DE SAISIE DE MATÉRIEL INFORMATIQUE Contexte :

Suspicion de fuite de données (Affaire LiZbiZ).

Localisation : Bureau.

Matériel : Laptop Windows, Numéro de série.

Méthode d'acquisition :

1. Photographie de l'état du laptop (allumé/éteint).
2. Acquisition de la mémoire vive (RAM) si allumé (Dump).
3. Arrêt propre ou retrait de batterie.
4. Clonage bit-à-bit du disque dur via un bloqueur d'écriture matériel. **Empreintes (Hashes) du clone :**

- MD5 : d41d8cd98f00b204e9800998ecf8427e
- SHA-256 : e3b0c44298fc1c149afbf4c8996fb92427...
- **Stockage** : Scellé n°[ID] placé dans un sac antistatique, stocké en armoire ignifugée à accès restreint.

Ex. 4.3 Politique de rétention

Pour satisfaire les trois juridictions, il faut s'aligner sur le standard le plus strict :

Pays	Référentiel applicable
Cameroun	Loi 2010/012 & Décrets ANTIC
Nigeria	NDPR (Nigeria Data Protection Regulation)
Côte d'Ivoire	Loi n°2013-450 (Protection des données à caractère personnel)

Proposition de Politique de Rétention Unifiée :

1. **Données Clients** : Conservation pendant toute la durée du contrat + **5 ans** après la fin de la relation (standard légal commun pour les litiges commerciaux).
2. **Logs de connexion** : Rétention de **1 an** (exigence standard pour les fournisseurs de services dans ces trois pays).
3. **Droit à l'oubli** : Mise en place d'une procédure de suppression sous **30 jours** sur demande justifiée de l'utilisateur, sauf obligation légale contraire.
4. **Localisation** : Hébergement prioritaire dans l'espace OHADA pour faciliter la coopération judiciaire.